

Cybersecurity Requirements

As per Cyber Resilience Act
Regulation (EU) 2024/2847

General Notes - Vatsal Patel

Summary of Overall CRA

Chapter	Core Concern
I - General provisions	What is covered? Introductory overview / Pre-requisite
II - Economic operators	What must manufacturers do? Development
III - Conformity	How is compliance demonstrated? Focus Area
IV - Assessment bodies	Who can assess conformity?
V - Market surveillance	Who checks/enforces compliance?
VI - Delegated powers	How can CRA be updated/supplemented?
VII - Confidentiality & penalties	What are the consequences of non-compliance?
VIII - Final provisions	How/when does CRA take effect?

Summary of Overall CRA

Product Security During Development Phase	Compliance & Market Access	Vulnerability Management During Complete Lifecycle
Secure Design Secure Development Secure Configuration Cryptography Access Control	Conformity Assessment Technical Documentation Declaration of Conformity CE Marking Market Surveillance	Monitoring Find & Fix CVEs Secure Updates Incident Handling Reporting

Work Distribution and Focus - 1/2

Development Team

Right Secure Design and Implementation

...

Deployment and Operational Team

Vulnerability Management

...

Work Distribution and Focus - 2/2

Development Team

- 1 Analysis -Threat and Risk Assessment
- 2 Design
 - Derive product security requirements,
 - Design Secure architecture,
 - Fundamentals - Cryptography, Authentication / Access Control, Identity, Privileges, Credentials
 - Features - Secure update, Secure boot, Security Logs
- 3 Secure implementation - Secure coding
- 4 Security testing - Functional Test, Fuzzing, Penetration testing
- 5 Component Management
 - SBOM/HBOM - Track third-party/open-source components
- 6 Vulnerability management
 - CVE monitoring, triage, remediation
- 7 Technical documentation - Produce CRA evidence

Deployment and Operational Team

- 1 Secure configuration - Configure product securely
- 2 Identity/access - Manage credentials, certificates, privileges
- 3 Security updates - Deploy authenticated updates
- 4 Vulnerability monitoring - Monitor CVEs/security advisories
- 5 Incident monitoring - Detect security incidents
- 6 Security logs/monitoring - Collect relevant security information
- 7 Incident response - Analyse and contain incidents
- 8 CRA reporting - Report applicable incidents / exploited vulnerabilities
- 9 Recovery - Restore secure operation after compromise
- 10 Lifecycle support - Maintain product throughout support period

Product Cybersecurity Requirements as per Annex I

Part 1 - Required Properties of the Product with Digital Elements

1 - Threat Modeling - Risk Identification

Consideration of appropriate Cybersecurity measures in Design, Development and Production

2 - Following 13 Cybersecurity requirements shall be considered,

Release of Product

2.a - Release Product without any known Vulnerabilities

continue...

Product Cybersecurity Requirements as per Annex I

Part 1 - Required Properties of the Product with Digital Elements

Cybersecurity Fundamentals (C, I, A, A)

2.e - Confidentiality of Data

2.f - Integrity of Data

2.h - Availability of Data/Service

2.d - Authentication for authorized Access

Feature Addition Consideration

2.l - Logging

2.c - Security Update

Architecture Consideration

2.b - Secure by Default

2.i - Minimize the dependency of other Device Services on Primary Product (Availability)

2.j - Limit Attack Surface

2.k - Reduced impact of exploitation by Mitigation Mechanism

Privacy Consideration

2.g - Data collections and usage minimisation

2.m - Deletion of all User Data and Settings

Product Cybersecurity Requirements as per Annex I

Part 2 - Vulnerability Handling Requirements

Routine Operation

- 1 - Vulnerability Identification, Monitoring, Documentation (SBOM/HBOM)
- 3 - Periodic Tests and Reviews

Resolution Measures for Identified Vulnerability

- 2 - Remediation - Security Update
- 7 - Secure Distribution of Patch/Fix (Auto-Update)
- 8 - Immediate Dissemination of Secure Updates and Info with advisory message

Public Interface for Reporting inbound and outbound

- 5 - Policy for coordinated Vulnerability Disclosure
- 6 - Facilitate the way for Reporting discovered Vulnerabilities
- 4 - Publicly Disclosure of Issue

Applicability of CRA

Digital product = hardware/software that has a direct or indirect data connection to another device or network.

The connection can be: Physical, Logical, Direct, Indirect

Applicable to every Electronics except standalone electronics application/machine which has absolutely NO communication connection outside its standalone unit.